



# AVALIAÇÃO DE SEGURANÇA

REST API — GO / GIN

EDIÇÃO PÚBLICA DE PORTFÓLIO

**Engajamento:** Teste de Penetração Autorizado

**Data:** 2026-08-29 · **Versão:** 1.0

CONFIDENCIALIDADE: SANITIZADO

## 02 / CONFIDENCIALIDADE & ESCOPO

### Edição Pública Sanitizada

This document is a **deliberately sanitized** edition of an authorized penetration-test report. All client-identifying information has been removed or masked: product and company names, real hostnames, IP addresses, tax identifiers (CNPJ), e-mail addresses, JWT values, request identifiers, and secrets.

A substância técnica — achados, severidade, formas de evidência e remediação — é preservada intacta para que o relatório continue sendo uma verdadeira demonstração de habilidade em assessment.

### Relatório Original – Confidencial

O relatório completo do engajamento (nome do cliente, evidência completa, detalhe de exploit live) **não** faz parte deste repositório. Pertence ao cliente e está protegido pelos termos de não-divulgação do engajamento. Qualquer reprodução deste portfólio está limitada ao conteúdo sanitizado apresentado aqui.

### Autorização & Regras de Engajamento

| ITEM               | DETALHE                                                                             |
|--------------------|-------------------------------------------------------------------------------------|
| Autorização        | Autorização formal de pentest, assinada                                             |
| Modelo             | Híbrido: white-box (inventário no código) + black-box (teste em runtime)            |
| Roles usadas       | customer / store_owner / admin (credenciais de pentest, rotacionadas)               |
| Fora de escopo     | Engenharia social, ataques a terceiros, DoS volumétrico, persistência               |
| Segurança de dados | Sem dados reais; indisponibilidade temporária e reset autorizados; artefatos limpos |

NOTA DO PORTFÓLIO: produzir entregáveis sanitizados é em si uma habilidade de segurança — esta edição demonstra como compartilhar conhecimento ofensivo sem expor um cliente.

## 03 / SUMÁRIO

|       |   |                                           |
|-------|---|-------------------------------------------|
| 04    | — | Resumo Executivo                          |
| 05    | — | Arquitetura da Aplicação                  |
| 06    | — | Metodologia                               |
| 07    | — | Ferramentas                               |
| 08    | — | Superfície de Ataque                      |
| 09–16 | — | Registro de Achados (8 cards em destaque) |
| 17    | — | Controles de Segurança Validados          |
| 18    | — | Matriz OWASP Top 10 (2021)                |
| 19    | — | Mapeamento MITRE ATT&CK                   |
| 20    | — | Roadmap de Hardening                      |
| 21    | — | Lições Aprendidas                         |
| 22    | — | Tecnologias Demonstradas                  |
| 23    | — | Radar de Skills                           |
| 24    | — | Sobre o Projeto                           |
| 25    | — | Conclusão                                 |

### Registro completo de achados

Os 22 achados (incluindo LOW / INFO e controles positivos) estão listados em [findings/severity-summary.md](#) no repositório. As páginas 09–16 trazem os oito cards de maior prioridade.

## 04 / RESUMO EXECUTIVO

Um assessment de segurança autorizado de uma **API REST de SaaS de delivery de comida** (Go / Gin) encontrou **nenhuma vulnerabilidade Crítica** e uma postura de segurança geralmente forte. Dois achados **HIGH** foram identificados — ambos são **regras de negócio ausentes**, não bugs de framework: uma lacuna de role-gate que permite um customer virar lojista, e uma constraint de unicidade ausente que permite registro em massa com um único identificador fiscal. Nenhum IDOR explorável, escalada de privilégio ou injeção foi encontrado.

**130**

ROTAS COBERTAS

**22**

ACHADOS

**2**

HIGH (CVSS 8.8 / 8.1)

**3**

ROLES TESTADAS

**4**

MEDIUM

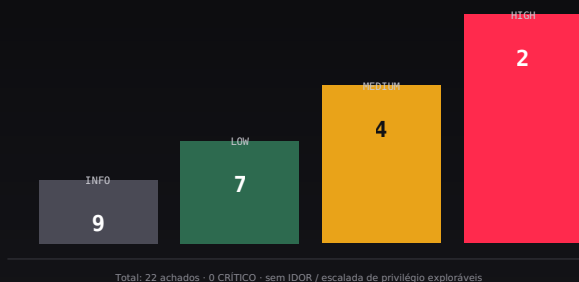
**7**

LOW

**9**

INFO

### ACHADOS POR SEVERIDADE



### Top 3 prioridades

- **F-01 (HIGH, CVSS 8.8):** qualquer customer autenticado pode criar uma loja e escalar para `store_owner`. Aplicar um role gate no `POST /store`.
- **F-02 (HIGH, CVSS 8.1):** o mesmo CNPJ pode ser registrado um número ilimitado de vezes em paralelo. Adicionar `UNIQUE(cnpj)` + conflito 409.
- **F-04 (MEDIUM, CVSS 6.5):** null-byte e payloads de 5 KB causam 500 bruto. Adicionar limite de tamanho (413) e decode robusto de entrada.

✓ **Pontos fortes dos controles:** Assinatura/claims do JWT validadas (alg:none rejeitado) · RBAC & propriedade estritos (sem IDOR) · uploads com validação por decode (SVG/HTML/polyglots todos bloqueados) · CORS restritivo · TLS 1.3 + HSTS + CSP `default-src 'none'` · auth com rate limit de 10/min.

# 05 / ARQUITETURA DA APLICAÇÃO

O alvo é um SaaS de delivery de comida multi-tenant: customers pedem de lojas de lojistas; lojas gerenciam menus, pedidos e pagamentos; um painel admin cuida das operações da plataforma. Uma API Go / Gin compartilhada atende os três front-ends além de uma camada de login OAuth.



## Inventário de rotas (autoritativo – do código-fonte)

| GRUPO         | ROTAS APROX. | AUTH         | EXEMPLOS                              |
|---------------|--------------|--------------|---------------------------------------|
| Infra         | 4            | nenhuma      | /health                               |
| Auth          | 7            | public       | /login/{role}, /auth/refresh          |
| OAuth         | 0-10         | pública      | Google / Apple (env-gated)            |
| Catálogo      | ~21          | JWT opcional | /cuisines, /stores, menus, items      |
| Protegido JWT | ~70          | obrigatória  | pedidos, favoritos, endereços, cupons |
| Admin         | 13           | role admin   | /admin/dashboard, usuários, lojas     |
| Webhooks      | 2            | assinatura   | /webhooks/billing, /webhooks/{id}     |

130 rotas fixas + 5 por provedor OAuth → máx. 140. A API é exposta diretamente (sem edge WAF), ao contrário dos front-ends protegidos por CDN — ver F-14.

## 06 / METODOLOGIA

### LINHA DO TEMPO DO ENGAJAMENTO



### Fases

| FASE          | TRABALHO REALIZADO                                                          | RESULTADO                                             |
|---------------|-----------------------------------------------------------------------------|-------------------------------------------------------|
| 1. Inventário | Mapa de rotas do código ( <b>RegisterRoutes</b> ); escopo & credenciais     | 130 rotas classificadas                               |
| 2. Recon      | Handshake TLS, headers, fingerprint, matriz de métodos                      | TLS 1.3, HSTS, CSP 'none'                             |
| 3. Auth       | Fluxos de login, adulteração de JWT, vínculo de refresh, loop de rate-limit | 10/min; alg:none rejeitado                            |
| 4. A01 Acesso | Bateria IDOR cross-role: users, stores, pedidos, endereços                  | Tudo bloqueado 403                                    |
| 5. Negócio    | Idempotência, cupons, auto-pedido, auto-registro de loja                    | F-01, F-02, F-06 encontrados                          |
| 6. Upload     | Bateria de MIME sniff: SVG, HTML, polyglot, null-byte, traversal            | Todos 400 — validação por decode                      |
| 7. Race       | Bursts paralelos: favorito, pedido, loja/CNPJ                               | Favoritos/pedidos idempotentes; race de CNPJ quebrada |
| 8. Automação  | ffuf (38 paths) + Nuclei (misconfig/exposures/cves)                         | Apenas headers ausentes (info)                        |
| 9. Limpeza    | Artefatos revertidos, aviso de rotação de credenciais                       | Ambiente limpo                                        |

### Cobertura OWASP 2021

As 10 categorias exercitadas com um plano de teste dedicado para cada — A01 Broken Access Control, A02 Cripto, A03 Injeção, A04 Insecure Design, A05 Misconfiguração, A06 Componentes Vulneráveis, A07 Auth, A08 Integridade (webhooks), A09 Logging, A10 SSRF.

## 07 / FERRAMENTAS

As ferramentas rodaram de um ambiente Linux (Gentoo) sob as regras de engajamento. A seleção foi deliberada: **nenhuma ferramenta foi usada por si só** — cada uma respondeu a uma pergunta.

| FERRAMENTA               | CATEGORIA    | PERGUNTA QUE RESPONDEU                                                                                                 |
|--------------------------|--------------|------------------------------------------------------------------------------------------------------------------------|
| <b>curl</b>              | Cliente HTTP | Fluxos de auth, bateria IDOR, loop de rate-limit, diferenciais de webhook                                              |
| <b>OpenSSL</b>           | Cripto/TLS   | Versão & cipher TLS: TLSv1.3, TLS_AES_128_GCM_SHA256                                                                   |
| <b>ffuf</b>              | Fuzzing      | Caminhos ocultos ( <code>/v1</code> , <code>/.env</code> , <code>/.git</code> , backups) → apenas <code>/health</code> |
| <b>Nuclei</b>            | Escaneamento | Templates de misconfig/exposição/CVE → apenas headers ausentes (info)                                                  |
| <b>Decodificador JWT</b> | Cripto       | Estrutura de claims; verificado alg:none & tokens adulterados rejeitados                                               |
| <b>Shell (bash)</b>      | Automação    | Bursts de race paralelos (10×/20×), parsing de status code, timing                                                     |

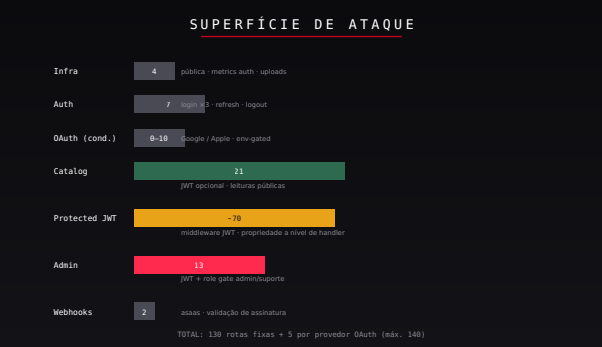
### Deliberadamente NÃO usado

| FERRAMENTA               | MOTIVO                                                                       |
|--------------------------|------------------------------------------------------------------------------|
| <code>sqlmap</code>      | Não disponível; a amostragem manual de SQLi cobriu os vetores de maior valor |
| DoS volumétrico          | Fora de escopo por contrato; apenas stress leve controlado permitido         |
| Persistência / implantes | Fora de escopo; regras do ambiente proíbem mudanças duradouras               |

✓ **Recomendação de CI:** versione a coleção `rest/*.http` / Postman e conecte Nuclei + ffuf ao CI para que cada mudança em `routes.go` seja re-validada automaticamente.

## 08 / SUPERFÍCIE DE ATAQUE

A API é o ponto único de entrada para três front-ends. A superfície foi mapeada exaustivamente pelo inventário do código e depois validada em runtime.



### Resumo de exposição

| CLASSE DE ENDPOINT   | RISCO  | COMENTÁRIO                                                                   |
|----------------------|--------|------------------------------------------------------------------------------|
| /health              | Info   | Apenas telemetria de uptime/latência; sem vazamento de versão                |
| Auth (login/refresh) | Low    | Rate limit de 10/min; sem lockout observado, mas também sem bypass           |
| Catálogo (público)   | Low    | Somente leitura; JWT opcional e ignorado quando inválido (F-10)              |
| Protegido JWT        | Medium | RBAC forte; o risco são as duas lacunas de regra de negócio (F-01/F-02)      |
| Admin                | Low    | Gate estrito de role admin; UUID inválido → 500 (F-05)                       |
| Webhooks             | Low    | Billing valida a assinatura primeiro; webhook de loja vaza existência (F-07) |
| Uploads              | Low    | Validação MIME por decode bloqueia todos os payloads testados                |

A automação confirmou a superfície: ffuf não achou rotas ocultas; Nuclei achou zero HIGH/CRITICAL. As rotas documentadas são a superfície de ataque completa deste ciclo.

## 09 / REGISTRO DE ACHADOS

### F-01 · Controle de Acesso Quebrado

F-01

**HIGH**

CVSS V3.1

8.8 (AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

CWE

CWE-269 · CWE-284

OWASP 2021

A01 — Broken Access Control

MITRE ATT&amp;CK

T1078 / T1548.002

#### Descrição

Qualquer **customer** autenticado pode chamar **POST /store** e receber um **200** com um **store\_id** válido — ganhando imediatamente capacidades de **store\_owner** (CRUD de menu, gestão de pedidos, acesso a webhooks). O endpoint não tem role gate; só verifica autenticação.

#### Impacto

Escalada vertical de privilégio: controle total de lojista de uma loja, seu menu, pedidos e configuração de pagamento sem ser um lojista aprovado. Combinado com F-02, é possível a criação em massa de lojas de propriedade do atacante.

#### Evidência (sanitizada)

```
POST /store
Authorization: Bearer <customer_jwt>
{"cnpj":"19.131.243/0001-97","name":"PORTFOLIO-STORE","category":"PIZZA"}
→ 200 {"store_id":"xxxxxxxx-xxxx-...", "cnpj":"...", "role_now":"store_owner"}
```

#### Remediação

Aplicar **role == store\_owner** antes da criação de loja (403), ou rotear a criação por um workflow de aprovação. Adicionar teste de regressão afirmando customer → 403.

# 10 / REGISTRO DE ACHADOS

## F-02 · Lógica de Negócio – Duplicação de CNPJ

F-02

HIGH

CVSS V3.1

8.1 (AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:H/A:H)

CWE

CWE-770 · CWE-307

OWASP 2021

A04 — Insecure Design

MITRE ATT&CK

T1499 / T1110

### Descrição

O mesmo CNPJ pode ser registrado em um número ilimitado de lojas. Tentativas **sequenciais** retornam **200** cada; bursts **10x paralelos** com um CNPJ também retornam todos **200** — provando que não há verificação de unicidade nem lock, não apenas uma janela de race.

### Impacto

Criação em massa de lojas com um único identificador fiscal: habilita fraude, onboarding de lojistas fictícios, abuso de avaliações/cupons e manipulação de estoque/billing. F-01 agrava.

### Evidência (sanitizada)

```
# 10x parallel
for i in $(seq 1 10); do curl -sk -X POST https://api.example.com/store \
  -H "Authorization: Bearer <store_jwt>" -d
  '{"cnpj":"19.131.243/0001-97","name":"S'$i',"category":"PIZZA"}' & done; wait
→ 10 × HTTP 200, 10 distinct store_ids
```

### Remediação

Adicionar constraint **UNIQUE(cnpj)**; retornar **409 cnpj already exists**; adicionar um teste de regressão de race (burst paralelo).

## 11 / REGISTRO DE ACHADOS

### F-03 · XSS Armazenado (candidato)

F-03

MEDIUM

CVSS V3.1

5.4 (AV:N/AC:L/PR:L/UI:R/S:C/L/I:L/A:N)

CWE

CWE-79

OWASP 2021

A03 — Injection

MITRE ATT&amp;CK

T1059.007

#### Descrição

PATCH /user/profile armazena "name":"<script>alert(1)</script>" literalmente (200). A API o escapa em JSON, então ele **não** executa nas respostas da API. O risco existe apenas se algum front-end renderizar este campo como HTML.

#### Impacto

XSS armazenado **se** um consumidor renderizar o campo sem sanitização: roubo de sessão/cookies, overlays de phishing ou comprometimento do dashboard da loja. Avaliado como MEDIUM (condicional).

#### Evidência (sanitizada)

```
PATCH /user/profile {"name":"<script>alert(document.cookie)</script>"} → 200
GET /user/xxxxxxx-... → {"name":"\u003cscript\u003ealert(document.cookie)\u003c/script\u003e"}
SSTI probes {{7*7}}, ${7*7}, <%=7*7%> → stored literally (NO template injection) ✓
```

#### Remediação

Sanitizar na escrita (remover <>) ou aplicar output-encoding em todo consumidor. Adicionar CSP que bloqueie script inline como defense-in-depth.

## 12 / REGISTRO DE ACHADOS

### F-04 · 500 Descontrolado em Null-Byte / Payload Grande

F-04

**MEDIUM**

CVSS V3.1

6.5 (AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H)

CWE

CWE-248 · CWE-400

OWASP 2021

A05 — Security Misconfiguration

MITRE ATT&amp;CK

T1499.001

#### Descrição

PATCH /user/profile com "name":"teste\u0000" ou um valor de 5000 chars retorna 500 bruto em vez de erro de validação. Não há limite de tamanho de payload nem tratamento gracioso de null bytes.

#### Impacto

Próximo a confiabilidade/DoS: requisições malformadas repetidas elevam a taxa de erro e poluem o monitoramento; 500s descontrolados podem mascarar incidentes reais e são um sinal de saúde do código.

#### Evidência (sanitizada)

```
PATCH /user/profile {"name":"teste\u0000"} → 500 internal error
PATCH /user/profile {"name":"A×5000"} → 500 internal error (no 413)
PATCH /user/profile {"name":12345} | [] | {} → 400 invalid request body ✓ (typing OK)
```

#### Remediação

Rejeitar null bytes (400), aplicar limite de corpo de 1 MB retornando 413 e adicionar um handler global de erros que retorne erros controlados em vez de 500 bruto.

## 13 / REGISTRO DE ACHADOS

### F-05 · 500 Não Tratado em Menu / Categoria / Lookup Admin

F-05

**MEDIUM**

CVSS V3.1

5.3 (AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L)

CWE

CWE-248 · CWE-214

OWASP 2021

A05 — Security Misconfiguration

MITRE ATT&amp;CK

T1499.001

#### Descrição

UUIDs inválidos em `menu/category` e `admin/user/{bad}` retornam `500` em vez de `400/404`. Os caminhos fazem parse de um UUID malformado e caem em um erro descontrolado.

#### Impacto

Próximo a divulgação de informação: 500s vazam o comportamento interno do handler, geram ruído de alertas e indicam validação ausente na fronteira do handler.

#### Evidência (sanitizada)

```
GET /menu/category/not-a-uuid → 500 internal error
GET /admin/user/not-a-uuid → 500 internal error (admin role)
GET /store/not-a-uuid/order → 403 (role gate runs BEFORE parse) ✓
```

#### Remediação

Validar a sintaxe do UUID antes da lógica do handler (`400`); retornar `404` quando o recurso realmente não existir; adicionar um middleware global de recover.

## 14 / REGISTRO DE ACHADOS

### F-06 · Rate Limit Ausente na Criação de Loja

F-06

MEDIUM

CVSS V3.1

5.3 (AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N)

CWE

CWE-770

OWASP 2021

A04 — Insecure Design

MITRE ATT&amp;CK

T1499 / T1110

#### Descrição

Os endpoints de auth têm rate limit de 10/min, mas **POST /store** não. 32 criações de loja em menos de 60 segundos produziram zero respostas **429**.

#### Impacto

Onboarding em massa de lojas fictícias (agrava F-01/F-02), inchaço do banco e fraude em chamados de suporte.

#### Evidência (sanitizada)

```
# 32 creations < 60s (2 init + 10 race + 20 stress)
for i in $(seq 1 20); do curl -sk -o /dev/null -w '%{http_code}\n' -X POST \
  https://api.example.com/store -H "Authorization: Bearer <store_jwt>" \
  -d '{"cnpj":"10.000.000/0001-"$i"', "name":"S"$i"', "category":"PIZZA"}'; done
→ 20 × HTTP 200 (zero 429)
```

#### Remediação

Aplicar o mesmo limiter de 10/min à criação de loja, chaveado por usuário + IP, com uma folga de burst para onboarding legítimo; alertar em picos.

## 15 / REGISTRO DE ACHADOS

### F-07 · Enumeração de Existência de Loja via Webhook

F-07

LOW

CVSS V3.1

3.7 (AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N)

CWE

CWE-204 · CWE-16

OWASP 2021

A08 — Data Integrity

MITRE ATT&amp;CK

T1595 / T1589

#### Descrição

POST /webhooks/{id} retorna 404 store payment config not found quando o id da loja é real mas sem config, versus 401 invalid webhook signature no webhook de billing. O lookup da config roda **antes** da validação da assinatura.

#### Impacto

Oráculo de existência de loja sem autenticação; habilita engenharia social direcionada e recon para abuso de F-01/F-02.

#### Evidência (sanitizada)

```
POST /webhooks/xxxxxxx-xxxx-... (no signature) → 404 store payment config not found
POST /webhooks/billing          (no signature) → 401 invalid webhook signature
# differential = existence oracle
```

#### Remediação

Validar a assinatura **antes** do lookup no banco e retornar um 401 genérico para todos os modos de falha.

## 16 / REGISTRO DE ACHADOS

### F-10 · Catálogo Ignora JWT Inválido

F-10

LOW

CVSS V3.1

2.6 (AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:N)

CWE

CWE-703 · CWE-345

OWASP 2021

A07 — Identification and Authentication Failures

MITRE ATT&amp;CK

T1078

#### Descrição

Endpoints públicos de catálogo aceitam um JWT **inválido/expirado/lixo** sem erro e servem os dados públicos — o token é silenciosamente ignorado. O comportamento é correto para os dados (públicos), mas a ignorância silenciosa mascara problemas de token dos clientes.

#### Impacto

Low: sem vazamento de dados (catálogo é público). É uma falha de observabilidade e consistência — os clientes não conseguem perceber que o token está quebrado.

#### Evidência (sanitizada)

```
GET /cuisines Authorization: Bearer garbage.token.here → 200 (public data served)
GET /cuisines Authorization: Bearer <expired_jwt>      → 200 (same)
GET /cuisines no header                               → 200 (same)
```

#### Remediação

Decidir a política: retornar **401** para token **presente-mas-inválido** nas rotas de catálogo (ou documentar a ignorância explicitamente). No mínimo, logar a anomalia.

## 17 / CONTROLES DE SEGURANÇA VALIDADOS

Um assessment tem duas metades: encontrar o que está quebrado e **provar o que funciona**. Cada controle abaixo foi ativamente atacado e se sustentou.

**Integridade do JWT** — ✓ `alg:none`, claims adulteradas e tokens expirados todos rejeitados com `401`. HS256 aplicado.

**RBAC & propriedade** — ✓ 20+ tentativas cross-role e cross-objeto em usuários, lojas, pedidos, endereços, cupons → todas `403`. Sem IDOR.

**Uploads** — ✓ SVG, HTML, PNG falso, polyglot, extensão dupla, null-byte e arquivos de traversal todos `400` — o servidor **decodifica** a imagem, não apenas o header.

**CORS** — ✓ sem reflexão de origin; `Origin` não permitida → `403`.

**Transporte** — ✓ somente TLS 1.3, `TLS_AES_128_GCM_SHA256`, HSTS + CSP `default-src 'none'` + XFO DENY.

**Rate limiting (auth)** — ✓ 10/min aplicado; spoofing de XFF (12 IPs rotativos) **não** burlou (F-21 positivo).

**Sem roteamento por Host-header** — ✓ `Host: evil.com` → `404`, vhost estrito (F-21).

**Idempotência (favoritos/pedidos)** — ✓ 10× paralelos → um único favorito, um único id de pedido.

**Cross-check de automação** — ✓ ffuf + Nuclei não encontraram exposição adicional (F-22 positivo).

Esses resultados são o que separa um run de scanner de um assessment liderado por engenharia: cada PASS é uma hipótese testada, não uma suposição.

## 18 / MATRIZ OWASP TOP 10 (2021)

COBERTURA OWASP TOP 10 (2021)

| CATEGORIA                         | STATUS         | RESULTADO                      |
|-----------------------------------|----------------|--------------------------------|
| A01 Broken Access Control         | RESISTENTE     | PASS - sem IDOR/BOLA           |
| A02 Falhas Criptográficas         | RESISTENTE     | TLS 1.3 - JWT forte            |
| A03 Injeção                       | NÃO OBSERVADO  | apenas amostragem              |
| A04 Insecure Design               | ACORDOS        | duplicação de CNPJ - escalada  |
| A05 Security Misconfiguration     | RESISTENTE     | headers - CORS - métodos       |
| A06 Componentes Vulneráveis       | NÃO VERIFICADO | sem SBOM exposto               |
| A07 Falhas de ID/Auth             | RESISTENTE     | rate limit - sem mass-assign   |
| A08 Integridade de Software/Dados | ACORDOS        | webhook fail-open              |
| A09 Logging e Monitoramento       | REVISÃO        | x-request-id presente          |
| A10 Server-Side Request Forgery   | NÃO TESTADO    | sem superfície de fetch de URL |

| A#  | CATEGORIA                 | RESULTADO DO ASSESSMENT                                                  | RELACIONADO      |
|-----|---------------------------|--------------------------------------------------------------------------|------------------|
| A01 | Broken Access Control     | <b>HIGH</b> role gate na criação de loja; no resto sólido                | F-01             |
| A02 | Falhas Criptográficas     | <b>PASS</b> TLS 1.3, HS256 aplicado, refresh vinculado ao device         | —                |
| A03 | Injeção                   | <b>MED</b> candidato a stored-XSS; sem SQLi/SSTI                         | F-03             |
| A04 | Insecure Design           | <b>HIGH</b> unicidade de CNPJ, rate limit ausente                        | F-02, F-06       |
| A05 | Security Misconfiguration | <b>MED</b> 500s descontrolados; 3 headers ausentes                       | F-04, F-05, F-13 |
| A06 | Componentes Vulneráveis   | <b>PASS</b> sem vazamento de versão; SBOM pendente                       | F-22             |
| A07 | Falhas de ID & Auth       | <b>LOW</b> catálogo ignora JWT inválido                                  | F-10             |
| A08 | Integridade de Dados      | <b>LOW</b> risco fail-open de webhook, oráculo de existência             | F-07, F-08       |
| A09 | Logging & Monitoramento   | <b>LOW</b> x-request-id presente; lacunas no log de auth                 | F-11             |
| A10 | SSRF                      | <b>PASS</b> sem superfície de fetch de URL externa; anotado para staging | —                |

## 19 / MAPEAMENTO MITRE ATT&CK

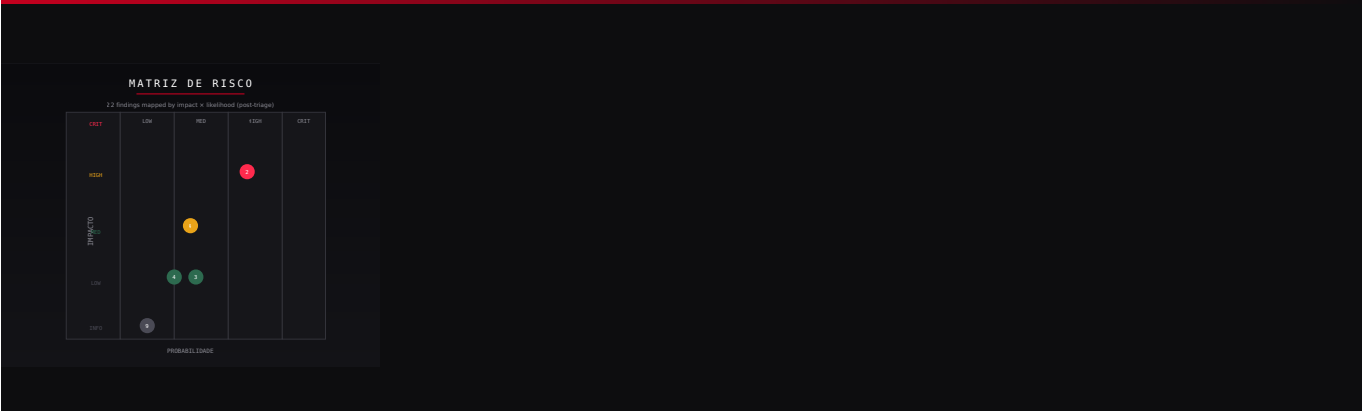
Achados mapeados para o ciclo de vida do adversário para mostrar prioridades de detecção/monitoramento.

| TÁTICA                 | TÉCNICA                | ACHADO / CONTROLE                      |
|------------------------|------------------------|----------------------------------------|
| Recon                  | T1595 / T1589          | F-07 oráculo de existência via webhook |
| Acesso Inicial         | T1078 (contas válidas) | F-01 caminho de escalada de loja       |
| Escalada de Privilégio | T1548.002              | F-01 customer → store_owner            |
| Impact / DoS           | T1499 / T1499.001      | F-02, F-04, F-05, F-06                 |
| Acesso a Credenciais   | T1110 (brute force)    | F-06, F-21 (mitigado: 10/min)          |
| Execução               | T1059.007 (JS)         | F-03 candidato a stored-XSS            |
| Coleta                 | T1557                  | Nenhum encontrado — sem BOLA/IDOR      |

### Recomendações de detecção

- Alertar em >10 `POST /store` por usuário por minuto (F-06/F-02).
- Correlacionar bursts de 404 em `POST /webhooks/{id}` → assinatura de recon (F-07).
- Monitorar 500s repetidos de payloads malformados (F-04/F-05) como ruído de scan.
- Alertar em uma única conta emitindo JWTs de `customer` e `store_owner` (F-01).

## 20 / ROADMAP DE HARDENING



### Imediato – 0-7 dias

| # | AÇÃO                                                                          | CORRIGE             |
|---|-------------------------------------------------------------------------------|---------------------|
| 1 | Role gate no <b>POST /store</b> (403) + teste de regressão                    | F-01                |
| 2 | <b>UNIQUE(cnpj)</b> + 409 + teste de race                                     | F-02                |
| 3 | Verificar secret de webhook definido em prod; 503 fail-closed quando vazio    | F-08                |
| 4 | Sanitizar <b>name</b> (rejeitar <>, null byte; 2-100 chars)                   | F-03/F-04/F-18/F-19 |
| 5 | Limite de corpo de 1 MB → <b>413</b> ; middleware global de recover           | F-04/F-05           |
| 6 | Rate-limit no <b>POST /store</b> (10/min) + rotacionar credenciais de pentest | F-06                |

### 30 dias – hardening

- Validar token de webhook antes do lookup no banco; 401 genérico (F-07).
- Fallback de rate-limit em memória quando Redis está fora (F-11).
- Padronizar nomenclatura da role **store\_owner** (F-12).
- Add **permissions-policy**, COOP, CORP + CI header check (F-13).
- Job de CI com Nuclei/ffuf cobrindo as 130 rotas (F-22).

### 60-90 dias – arquitetura & lógica de negócio

- Edge WAF/CDN para a API; limite por IP na borda (F-14).
- Tokens baseados em cookie (httpOnly/Secure/SameSite) com rotação de refresh.
- Teste de lógica financeira: race de cupom, máquina de estados do pedido, fuzz de variant/addon (F-09/F-16).
- Revisão de SSRF em fetches de URL externa; SBOM + **security.txt** + govulncheck no CI (F-22).

## 21 / LIÇÕES APRENDIDAS

### 1. Controles positivos valem tanto quanto achados

Os resultados negativos — cada IDOR, polyglot de upload e tentativa de CORS que foi bloqueada — são evidência de que os controles **funcionam**. Um relatório que prova que as defesas funcionam é mais crível do que um que só lista bugs.

### 2. Teste o modelo de negócio, não só o framework

Os dois HIGHs (F-01, F-02) eram **regras de negócio ausentes** — sem role gate, sem constraint de unicidade. Nenhum scanner encontra isso. Essa é a diferença entre rodar ferramentas e conduzir um assessment.

### 3. Race conditions precisam de teste paralelo, não sequencial

A duplicação de CNPJ só se tornou comprovável com bursts paralelos de 10x/20x. Um re-teste sequencial teria mostrado "um por chamada" e perdido completamente o lock ausente.

### 4. Severidade é sobre contexto de negócio

O mesmo rate limit ausente é LOW num caminho de leitura e MEDIUM num caminho de escrita que habilita fraude em massa. Contexto — não tabelas de consulta — determina a severidade.

### 5. Entrega é um produto

Um plano de remediação de 7/30/60/90 dias, um roadmap com donos e uma seção clara de autorização/escopo tornam um pentest **acionável**. O relatório não é o entregável — a **decisão que ele habilita** é.

## 22 / TECNOLOGIAS DEMONSTRADAS

### GO / GIN

STACK ALVO ANALISADA

### JWT / HS256

TESTE DE AUTH & TOKEN

### TLS 1.3

VALIDAÇÃO DE TRANSPORTE

### Disciplinas de assessment exercitadas

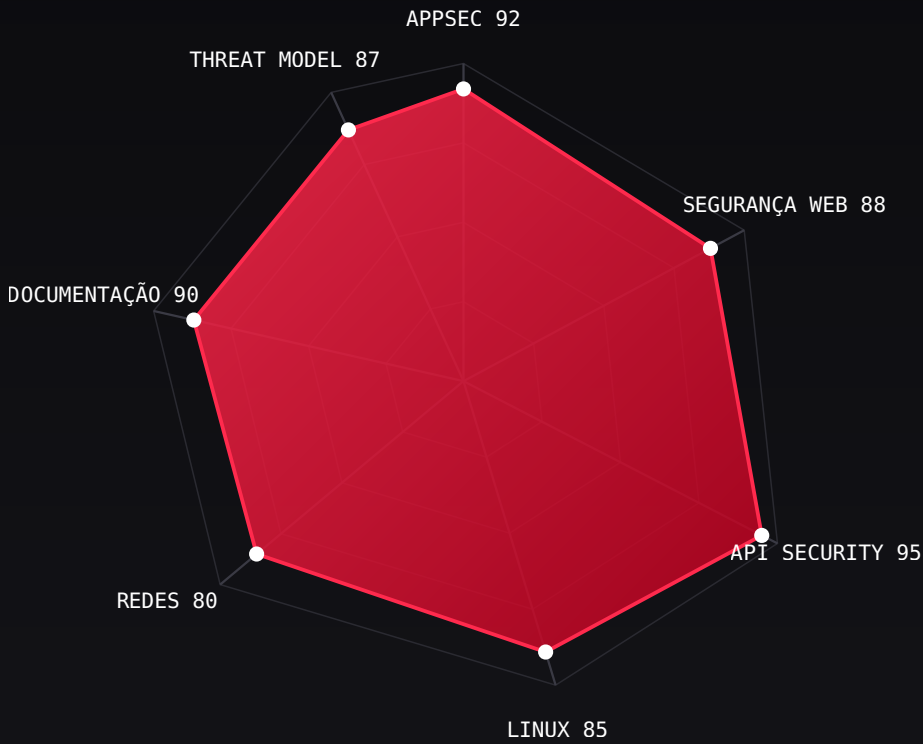
- **Web App Security:** bateria OWASP Top 10, amostragem de injeção, XSS, CORS, CSP, headers
- **API Security:** inventário de 130 rotas, RBAC/propriedade (BOLA/IDOR), mass-assignment, matriz de métodos
- **Lógica de Negócio:** idempotência, race conditions, máquinas de estado, auto-pedido
- **Criptografia:** adulteração de algoritmo JWT, revisão de cipher TLS, vínculo de refresh token
- **Linux & Automação:** curl, OpenSSL, ffuf, Nuclei, shell scripting paralelo
- **Documentação & Relatório:** sanitização, mapeamento CVSS/CWE/OWASP/ATT&CK, roadmap

### Resultado a nível de framework

O framework (Gin) se sustentou: os achados significativos estavam na **camada de negócio** (política de autorização, constraints de integridade de dados), não no framework web. Esse é o perfil de um codebase maduro e de um assessment direcionado, não de chumbo grosso.

## 23 / RADAR DE SKILLS

### RADAR DE SKILLS



Auto-avaliado em um engajamento live — validado por cobertura de 130/130 rotas e 22 achados classificados

Auto-avaliado em um engajamento live — fundamentado em cobertura de 130/130 rotas, 150+ requisições construídas, 10/10 categorias OWASP e 22 achados classificados.

## 24 / SOBRE ESTE PROJETO

### Por que este portfólio existe

Este repositório é uma **demonstração de engenharia de segurança ofensiva**: como um engajamento autorizado real é planejado, executado, documentado, sanitizado e transformado em um roadmap acionável — sem nunca expor o cliente.

### O que está incluído

- **findings/** — 22 cards individuais de achados (F-01...F-22 + registro)
- **evidence/** — trechos canônicos sanitizados de requisição/resposta
- **assets/** — 9 diagramas customizados (arquitetura, superfície de ataque, fluxos...)
- **methodology.md / timeline.md / tools.md** — o "como"
- **hardening-roadmap.md** — 24 ações priorizadas com donos
- **portfolio-notes.md** — revisão sênior do relatório original + lições

### O que é deliberadamente NÃO incluído

- Nome do cliente, hostnames reais, IPs, CNPJs, e-mails, tokens, segredos
- Instruções de exploit live contra o ambiente de produção
- Qualquer conteúdo sob o NDA do engajamento original

### Contato / roles alvo

Security Engineer · Penetration Tester · Security Consultant · AppSec Engineer. Foco: API security, segurança de aplicações web, testes de lógica de negócio e relatórios de segurança.

## 25 / CONCLUSÃO

A API avaliada é **fundamentalmente sólida**: segurança de transporte forte, integridade de JWT aplicada, RBAC/propriedade estritos, uploads validados por decode e CORS restritivo. Nenhuma vulnerabilidade Crítica e nenhum IDOR explorável, injeção ou cadeia de escalada de privilégio foi encontrada.

O risco residual se concentra em **duas lacunas de regra de negócio** (F-01 role gate, F-02 unicidade de CNPJ) que habilitam fraude de lojistas em escala. Ambas são baratas de corrigir e são as prioridades máximas do roadmap. Todos os demais achados são melhorias de hardening e confiabilidade.

|                       |          |                   |
|-----------------------|----------|-------------------|
| 22                    | 0        | 130               |
| ACHADOS CLASSIFICADOS | CRÍTICOS | ROTAS VERIFICADAS |

– FIM DO RELATÓRIO –

Relatório de Avaliação de Segurança · Edição Pública de Portfólio · Versão 1.0 · 2026-08-29  
Sanitizado para distribuição pública · O relatório original permanece confidencial

## A / ADENDO DE REAVALIAÇÃO

Este adendo acrescenta achados identificados em reavaliação posterior (outubro de 2026). Ele **complementa** o relatório v1.0 e **não altera** os achados nem as classificações das páginas anteriores. As classificações marcadas como “preliminar” ainda estão em consolidação e não reaproveitam o CVSS do relatório original.

### F-23 · Isolamento Multi-Tenant Quebrado

F-23

**CRÍTICO****CLASSIFICAÇÃO**

Crítico (reportado na reavaliação)

**OWASP 2021**

A01 — Broken Access Control

#### Descrição

Identifiquei uma falha crítica de isolamento multi-tenant em que alterações realizadas em um restaurante eram refletidas em outro estabelecimento distinto. O comportamento indicava quebra de segregação entre tenants e risco de alteração indevida de dados entre contas diferentes.

#### Impacto

Quebra de segregação entre tenants: alterações feitas no contexto de um estabelecimento podem atingir dados de outra conta, com risco de modificação indevida de informações entre restaurantes distintos e perda de integridade e confiança na separação entre contas.

#### Evidência

Evidência sanitizada – detalhes técnicos omitidos na edição pública.

#### Remediação

Garantir escopo de tenant em todas as operações de escrita e leitura, com verificação de propriedade no servidor para cada recurso acessado; adicionar testes de regressão que afirmem o isolamento entre estabelecimentos distintos.

## A / ADENDO DE REAVALIAÇÃO

### F-24 · Controle de Acesso entre Lojas (BAC / IDOR)

F-24

**ALTO (PRELIMINAR)****CLASSIFICAÇÃO**

Preliminar (reavaliação)

**OWASP 2021**

A01 — Broken Access Control

#### Descrição

Identifiquei que era possível alterar manualmente o identificador de uma loja na URL e acessar outro restaurante, comportamento posteriormente confirmado pela equipe como não esperado. O achado foi tratado como Broken Access Control / IDOR.

#### Impacto

Acesso indevido a outro estabelecimento por manipulação direta do identificador, indicando verificação de autorização insuficiente no nível do objeto (BOLA/IDOR) entre lojas.

#### Evidência

Evidência sanitizada – detalhes técnicos omitidos na edição pública.

#### Remediação

Validar, no servidor, se o recurso solicitado pertence ao tenant/loja do usuário autenticado antes de responder; evitar identificadores sequenciais previsíveis e cobrir o caso com teste de autorização negativa.

## A / ADENDO DE REAVALIAÇÃO

### F-25 · Cadastro sem Validação Adequada

F-25

**MÉDIO (PRELIMINAR)****CLASSIFICAÇÃO**

Preliminar (reavaliação)

**OWASP 2021**

A04 — Insecure Design

#### Descrição

Identifiquei que a plataforma permitia a criação de contas utilizando CNPJ, telefone e e-mails sem validação adequada, inclusive com domínios arbitrários, possibilitando cadastros falsos e abuso do fluxo de onboarding.

#### Impacto

Criação de cadastros falsos e abuso do fluxo de onboarding, com inchaço da base, dados não confiáveis e abertura para fraude no cadastro de contas e estabelecimentos.

#### Evidência

Evidência sanitizada – detalhes técnicos omitidos na edição pública.

#### Remediação

Validar CNPJ, telefone e e-mail (formato e domínio) no onboarding, com verificação de posse (confirmação de e-mail/telefone) e controles anti-abuso no fluxo de criação de contas.